TECHNICAL DETAIL

Title	Stored Cross-Site Scripting (XSS) via SVG File Upload targeting Administrator
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://bertani.my.id/admin/posts
Severity	**Medium**
CVSS Score	**5.4** **CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N**
Proof of Concepts	Please see Steps to Reproduce section

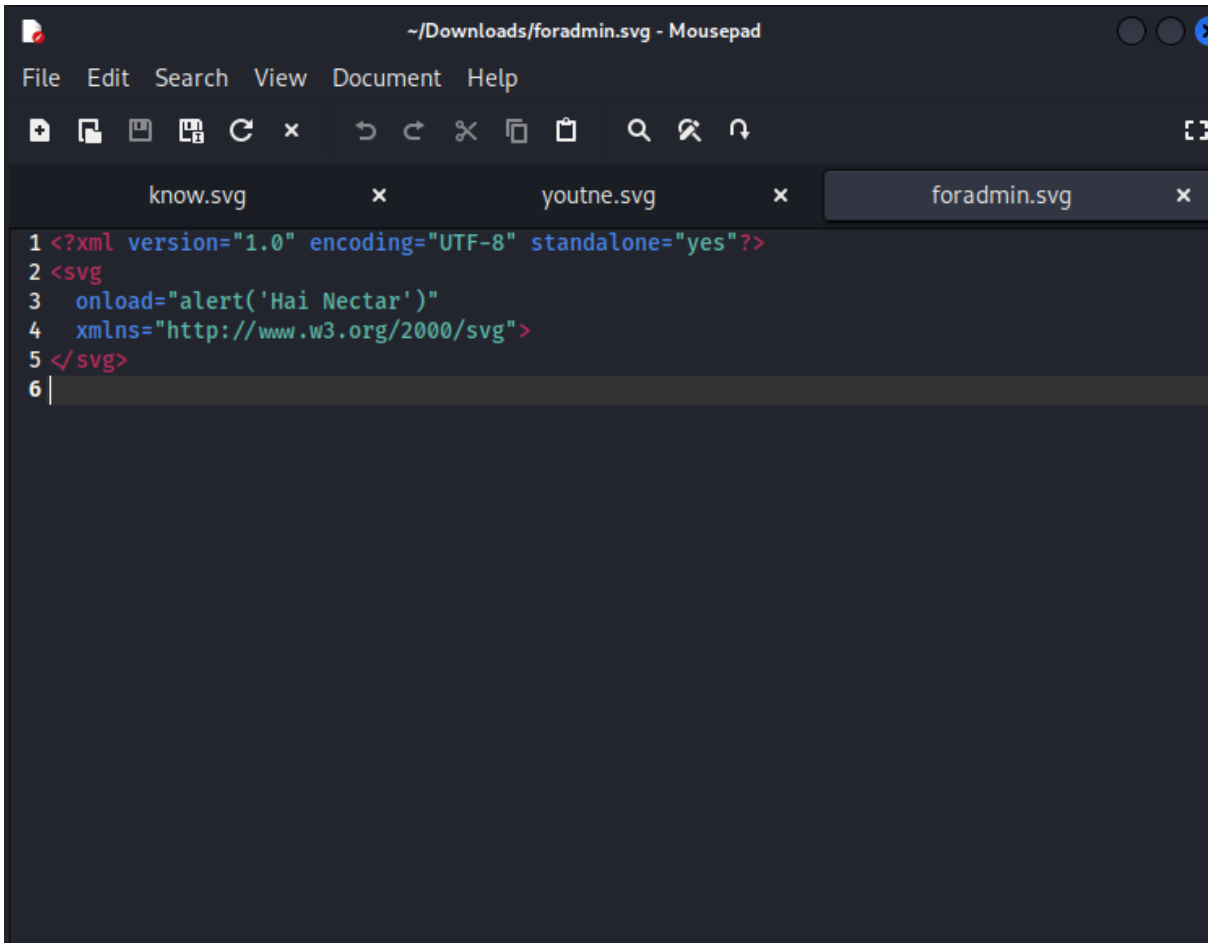
SUMMARY

Kerentanan **Stored Cross-Site Scripting (XSS)** ditemukan pada fitur unggah berkas (file upload) di fungsi "Knowledge Create". Aplikasi mengizinkan pengguna untuk mengunggah berkas dengan format .svg tanpa melakukan sanitasi yang memadai terhadap konten XML di dalamnya. Penyerang dapat menyisipkan skrip JavaScript berbahaya ke dalam berkas SVG tersebut. Karena berkas disimpan secara permanen di server, skrip tersebut akan dieksekusi di sisi browser administrator saat mereka mencoba melihat lampiran atau gambar melalui halaman manajemen postingan

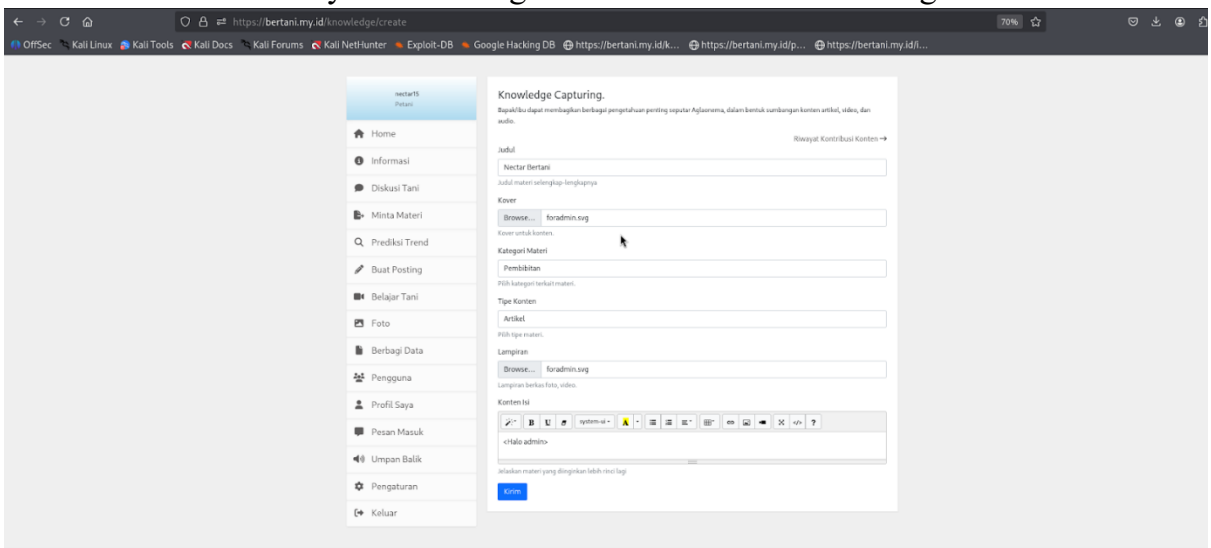
STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai user di URL https://bertani.my.id/login

2. Buat file svg yang berisi

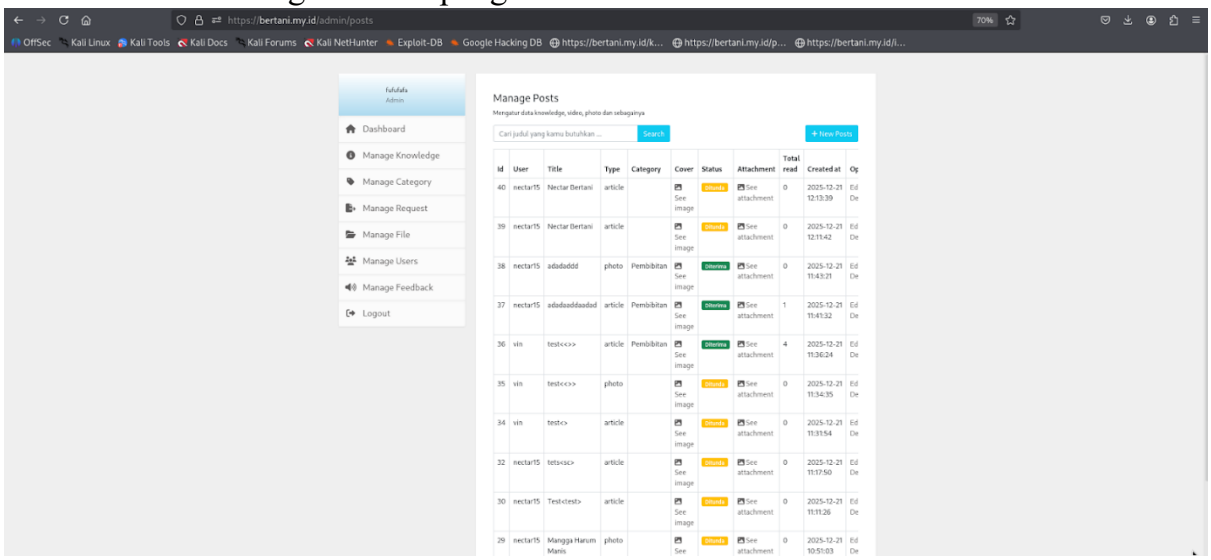


3. Masuk ke url bertani.my.id/knowledge/create dan masukan file svg tersebut

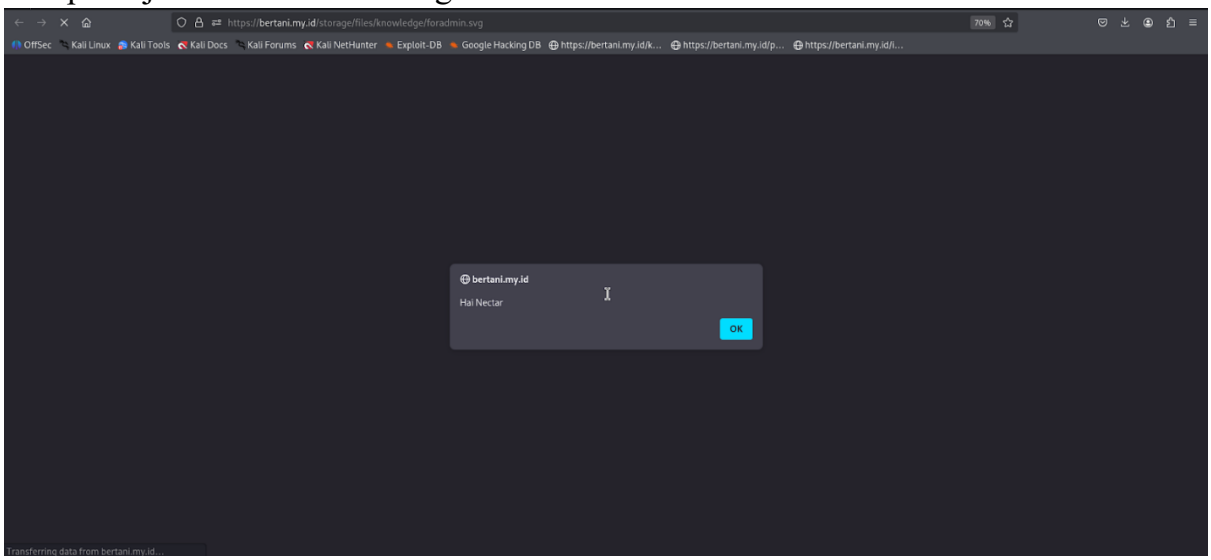


4. Login ke Akun Anda sebagai admin di URL https://bertani.my.id/login

5. Masuk ke url bertani.my.id/admin/posts Maka saat admin menekan see attachment / see image akan terpengaruh



6. Tampilan jika admin menekan gambar



EXPECTED RESULT

Aplikasi seharusnya memvalidasi dan membersihkan (sanitize) setiap konten dalam berkas SVG untuk menghapus elemen berbahaya seperti <script> atau atribut event handler (seperti onload) sebelum berkas disimpan ke server.

Berkas yang diunggah oleh pengguna sebaiknya disajikan dengan header respons Content-Disposition: attachment, sehingga browser akan mengunduh berkas tersebut alih-alih merender dan mengeksekusi skrip di dalamnya secara langsung.

ACTUAL RESULT

1. Aplikasi menerima dan menyimpan berkas .svg yang mengandung muatan (payload) JavaScript berbahaya secara mentah.
2. Saat administrator mengakses URL berkas di https://bertani.my.id/storage/files/knowledge/foradmin.svg, browser menjalankan instruksi JavaScript alert('Hai Nectar') yang ada di dalam berkas tersebut.
3. Hal ini membuktikan bahwa skrip dapat berjalan dalam konteks sesi pengguna yang sedang membuka berkas tersebut

IMPACT

1. **Admin Account Takeover**: Penyerang dapat mencuri *session cookies* Administrator saat mereka melihat daftar lampiran di panel *Manage Posts*.
2. **Privilege Escalation**: Memungkinkan pengguna tingkat rendah (Petani) untuk menyerang otoritas yang lebih tinggi yaitu admin melalui fitur unggah kover/lampiran.

RECOMMENDATION

1. Sanitasi File SVG: Gunakan library seperti DOMPurify (di sisi server) untuk menyaring elemen-elemen berisiko pada berkas SVG sebelum disimpan.
2. Implementasi Content Security Policy (CSP): Terapkan header CSP yang ketat untuk mencegah eksekusi skrip inline dan membatasi sumber skrip yang diizinkan.
3. Gunakan Header Keamanan: Pastikan server mengirimkan header X-Content-Type-Options: nosniff dan memaksa pengunduhan untuk berkas statis yang diunggah pengguna menggunakan Content-Disposition: attachment.
4. Validasi Tipe Berkas: Jika SVG tidak benar-benar diperlukan, pertimbangkan untuk membatasi unggahan hanya pada format gambar raster seperti .jpg atau .png.

REFERENCES

1. **OWASP - Unrestricted File Upload:** https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
2. **PortSwigger - Stored XSS via SVG File:** https://portswigger.net/web-security/cross-site-scripting/stored